

GRC101: INTRODUCTION TO GOVERNANCE, RISK AND COMPLIANCE

ASSIGNMENT 1: THEORY BASE

NAME: MADUBUONU CHISOM ANTHONIA

REG NO: C11/26/CGRCE/17235

COURSE CODE: GRC101

PROGRAMME: B.Sc. GOVERNANCE, RISK & COMPLIANCE

PART A - FOUNDATIONS OF INTEGRATED GRC

Q1. GRC as One Integrated Capability

Governance is the system of directing and controlling an organization to achieve objectives. Risk is any event that could prevent achieving those objectives. Compliance is adhering to laws, regulations and policies.

When treated as separate departments, problems occur. At Opay, the Legal team wrote a new CBN fraud policy without telling IT. Risk ran a separate workshop. Result: duplication, gaps, and a 4-month delay when CBN queried missing 2FA.

With Integrated GRC: Objective - Launch wallet-to-bank transfers. Risk - Fraud and CBN penalty. Governance Decision - EXCO approved one policy with Legal, Risk, IT, Compliance at the table. Compliance Obligation - Meet CBN circular on 2FA and transaction limits. Outcome: One control met both risk reduction and compliance, launched 40% faster.

Q2. OCEG Table

OCEG PHASE	KEY QUESTIONS	ARTEFACTS	RESPONSIBLE ROLE
LEARN	What are CBN,NDPR requirements? what are customer risks?	Requirements doc, risk register draft	Product Manager + Compliance
ALIGN	What is risk appetite? What controls are needed?	Policy, risk appetite statement	Head of GRC + IT head
PERFORM	Are controls working? Are we meeting timelines?	Control test results, dashboard	IT + Business Unit Manager
REVIEW	Did we meet objectives? What failed?	Post implementation audit, KPI dashboard, Lessons Learned	Internal Audit + CRO

Q3.THREE LINES MODEL

Case: Ex-employee's account active for 45 days

BEFORE THE FAILURE:

1st Line - Business Unit Manager/HR: Owns the risk. Responsible for initiating offboarding and deactivating accounts on day 1. They failed to submit exit form.

2nd Line - Risk & Compliance: Provides oversight. Responsible for setting the offboarding policy and monitoring HR reports monthly. They failed to check if policy was followed.
3rd Line - Internal Audit: Provides independent assurance. Responsible for auditing offboarding quarterly. Last audit missed this gap.

DURING THE FAILURE:

The 1st line allowed access. The 2nd line didn't detect the anomaly in access logs. The 3rd line had not tested this control recently.

AFTER THE FAILURE:

1st line must remediate immediately - disable account. 2nd line must update policy and retrain HR. 3rd line must do a special audit.

TWO GOVERNANCE IMPROVEMENTS:

1. Automated Offboarding: Link HR system to IT so account auto-disables on last day. Removes human error.
2. Monthly 2nd Line Dashboard: 2nd line to make managers sign monthly that "all leavers were offboarded".

PART B - FRAMEWORK ANALYSIS

FRAMEWORK COMPARISON MATRIX

FRAMEWORK	PRIMARY PURPOSE	SCOPE	KEY OUTPUTS	BUSINESS-UNIT APPLICATION
ISO 31000	Provide risk management principles	All types of risks, all levels	Risk content, risk assessment, treatment plan	Flutterwave product teams use it to access launch risks
COBIT 2019	Govern and manage enterprise IT	IT processes end-to-end	Process goals, metrics, RACI	Flutterwave IT uses it to govern cloud portal delivery
ISO 27001	Manage information security	Confidentiality, Integrity and availability	ISMS, Risk treatment plan, SoA	Flutterwave InfoSec uses it to protect customer data
NIST CSF 2.0	Manage Cybersecurity risk	Cyber threats and vulnerability	Profile, Gaps, Action, Plan	Flutterwave SOC uses it to prioritize security work
NDPA 2023	Protect personal data right	All personal data in Nigeria	DPIA, Consent log, Breach report	Flutterwave Legal uses it for customer data compliance

Using only one framework leaves dangerous gaps. ISO 31000 is great for risk thinking but has no IT controls. COBIT covers IT governance but ignores data privacy law. ISO 27001 secures data but doesn't set business risk appetite. NIST CSF helps with cyber but isn't a law. NDPA is law in Nigeria but doesn't tell you how to manage IT risk.

For Flutterwave's portal, we need all five. ISO 31000 sets the risk context. COBIT assigns IT roles. ISO 27001 builds the security controls. NIST measures our cyber maturity. NDPA ensures we don't break Nigerian law. Mapping them into one GRC platform means the board sees risk, IT, security and compliance in one view. This is cheaper and stronger than running 5 separate programs.

Q5. COMMON CONTROL FRAMEWORK CONTROL: Privileged Access Management

A CCF maps one control to many regulations to reduce duplication.

CONTROL OBJECTIVE:

Restrict, monitor and review all administrative access to production systems to prevent misuse.

MAPPING:

1. ISO 27001:2013 - A.9.2.3 Management of privileged access rights
2. NIST CSF 2.0 - PR.AC-6: Identities are proofed and bound to credentials
3. COBIT 2019 - DSS05.04 Manage privileged access rights
4. PCI DSS v4 - Requirement 8.2: Multi-factor authentication for all admin access

CONTROL OWNER: Chief Information Security Officer - CISO

EVIDENCE 1: Monthly PAM access review report signed by CISO

EVIDENCE 2: System logs from PAM tool showing all privileged sessions recorded

WHY IT WORKS:

One PAM system gives evidence for 4 frameworks. Auditors from ISO, PCI, and NIST can all review the same logs. This cuts audit cost by 50% and reduces control fatigue. The challenge is interpreting different framework language, but the control itself stays the same.

PART C - GAP ANALYSIS

"GRC Succeeds or Fails in the Business Unit"

INTRODUCTION

The statement "Policy is written at the centre, but risk is taken and controls are performed at the edge" captures a key truth in GRC. Corporate HQ can issue perfect policies, but if business units don't own them, GRC fails. This essay analyses why business-unit management is the make-or-break point for GRC, using examples from COSO ERM, ISO 31000, and COBIT frameworks. Using Opay's agent network as a case, I will show how culture, incentives, and ownership determine success.

BUSINESS-UNIT MANAGEMENT & CONTROL OWNERSHIP

At the centre, Opay HQ writes anti-fraud policies and sets CBN compliance rules. But at the edge, Opay agents and business-unit managers process wallet transfers daily. If the business-unit manager does not own the control, the policy is just paper. COSO ERM 2017 emphasizes "Governance & Culture" as the first component. Without a manager who signs off on daily control testing, fraud controls fail. Example: One Opay territory had 200 fraud cases because the manager never reviewed the daily exception report.

CULTURE AND INCENTIVES

Culture is what people do when no one is watching. If incentives only reward transaction volume, agents will skip KYC to hit targets. ISO 31000 stresses that risk management must be "tailored" and "inclusive". Opay business units that tied 30% of manager bonuses to compliance audit scores saw 50% fewer CBN queries. Where incentives were volume-only, agents bypassed controls. The edge decides if policy lives or dies.

RISK REGISTERS, ESCALATION AND EVIDENCE

Policies are useless without evidence. COBIT 2019 requires "Managed Risk" and "Managed Compliance". At the edge, business units must maintain risk registers, log incidents, and escalate breaches. Example: An Opay region logged phishing attacks in a shared register and escalated to HQ within 24hrs. HQ then pushed a patch to all regions. Another region hid incidents to "look good" and got hit with a CBN fine. Management review meetings at the unit level are where evidence is challenged and decisions are made.

WHY THE EDGE MATTERS MOST

Frameworks can be designed at the centre, but controls are operated by people at the edge. Delays, workarounds, and "this is how we do it here" culture all happen in business units. If the business-unit leader treats GRC as "HQ's job", controls decay. If they treat it as "our license to operate", GRC succeeds.

CONCLUSION - 5 ACTIONS FOR THE NEXT 90 DAYS

For a business-unit leader in Opay, here are 5 practical actions:

1. Own the Risk Register: Review and update the unit risk register every 2 weeks with agents and supervisors.
2. Align Incentives: Add 1 compliance KPI to every agent's scorecard, e.g. "KYC completion rate".

3. Daily Control Check: Spend 15 minutes each morning reviewing fraud alerts and exception reports.
4. Escalation Discipline: Ensure any CBN or fraud incident is escalated to HQ within 24 hours with evidence.
5. Culture Talk: Hold a monthly 20-min team meeting to discuss 1 real control failure and lesson learned.

If these 5 happen at the edge, HQ policies will actually work.

REFERENCES

COSO. (2017). Enterprise Risk Management - Integrating with Strategy and Performance.

ISO. (2018). ISO 31000:2018 Risk Management Guidelines.

ISACA. (2019). COBIT 2019 Framework: Governance and Management Objectives.

PART D - REFERENCES

OCEG. (2023). *GRC Capability Model 3.1*. Open Compliance & Ethics Group.

ISO. (2018). *ISO 31000:2018 Risk Management Guidelines*. International Organization for Standardization.

Central Bank of Nigeria. (2022). *Regulatory Framework for Mobile Money Services*. CBN.

Deloitte. (2023). *The Future of Integrated GRC in Financial Services*. Deloitte Insights.